

세션 방식

사용자가 로그인하면 서버가 메모리에 적어두고 브라우저에게는 세션 ID만 쥐여주고 이후 사용자는 ID만 들고 다닙니다.

JWT 방식

사용자가 로그인하면 서버는 사용자의 정보와 만료 시간 등을 담아 암호화된 토큰(JWT)을 만들어 사용자에게 줍니다. 토큰이 위조되었는지만 확인합니다.

Session과 JWT의 차이

세션의 장점

1. 즉각적인 강제 로그아웃(세션만료) 가능

세션의 경우: 사용자가 스마트폰을 분실했거나, 해킹이 의심되거나, 은행 점검 시간이 되면 서버에서 해당 세션을 무효화(**invalidate**)해 즉시 접속을 끊어버릴 수 있습니다.

JWT의 경우: 토큰은 한 번 발급되면 그 자체로 유효기간이 끝날 때까지 서버의 통제권을 벗어납니다. 만약 해커가 토큰을 탈취했다면, 서버는 그 토큰이 만료될 때까지 해커의 접근을 막기가 매우 까다롭습니다. (블랙리스트 등을 구현해야 하지만, 이 경우 결국 세션처럼 서버에 정보를 저장해야 하므로 **JWT**의 장점이 사라집니다.)

2. 중복 로그인 차단

세션의 경우: 서버 장부에 현재 로그인된 세션을 기록해 두기 때문에, 새로운 기기에서 로그인하면 기존 세션을 끊어버리는 등 완벽한 1인 1로그인 제어가 가능합니다.

JWT의 경우: 무상태(Stateless)의 특성상 서버가 각 사용자의 상태를 기억하지 않기 때문에, 동일한 토큰으로 여러 기기에서 동시에 요청을 보내도 알아채기 어렵습니다.

JWT 장점

뛰어난 서버 확장성

사용자가 늘어나면 서버 메모리가 부족해지거나 서버를 여러대로 늘렸을 때 세션 정보를 동기화하는 복잡한 과정이나 **Redis** 같은 별도 DB구축이 필요합니다.

토큰 자체가 유효한 입장권 역할을 하므로, 서버가 여러 대로 늘어나도 상관없습니다. 1번 서버에서 발급받은 토큰을 2번 서버에 보여 줘도 2번 서버는 자신의 가진 비밀키로 서명만 검증하면 바로 통과 시켜 줄 수 있습니다.